

VISN 1 NETWORK CONSOLIDATED LABORATORY
VA CONNECTICUT HEALTHCARE SYSTEM
West Haven Campus, Pathology & Laboratory Medicine Service
Microbiology/Mycobacteriology Department

1. BPA LANGUAGE

- 1.1. **INTENT:** The Department of Veterans Affairs, (herein afterwards referred to as VISN (1) intends to establish a Blanket Purchase Agreement (BPA) for BD BACTEC MGIT 960 for fully automated Tuberculosis culture growth, detection, and susceptibility testing. The Government will award a CPT BPA to a single Contractor. Contractor agrees to the following terms of the BPA exclusively with the VISN facilities listed herein and awarded in the final BPA. However, as requirements change, facilities within VISN 1 may be added or deleted by supplemental agreement of the Government and the Contractor. Additional tests/reagents/instrumentation may be added to the BPA as government needs change or as new technology becomes available on the market.
- 1.2. **PRICES AND TERMS:** VISN 1 will provide an estimated volume for each individual medical center and outpatient clinic laboratory. The Government estimates the volumes per facility but does not guarantee volumes as listed; they are estimates only. This BPA does not obligate any funds. The Government is obligated only to the extent of authorized orders actually issued under the BPA by authorized individuals.
- 1.3. **TERM OF AGREEMENT:** This will be a single award, firm-fixed price Cost Per Test (CPT) BPA with one base year and four, one-year options, with the option for a 6-month extension. This BPA shall be reviewed annually. VISN 1 intends to establish the base year of the agreement for the period of 5/17/2025 through 5/16/2026.
- 1.4. **IDENTIFICATION:** Delivery Orders issued shall be identified by their BPA Number. BPA identification numbers are assigned through the VHA Procurement Activity.
- 1.5. **ORDERING METHOD:** The participating facilities may order products via Electronic Data Interchange (EDI), telephone, facsimile, or other written communication, identifying the products by number, quantity, address for delivery, and any special instructions.

2. DESCRIPTION/SPECIFICATIONS/STATEMENT OF WORK

2.1. SCOPE OF PROCUREMENT:

- 2.1.1. The contractor shall provide one BACTEC MGIT 960 per each clinical laboratory listed.

VA Connecticut West Haven 950 Campbell Ave. West Haven CT, 06516
--

- 2.1.2. New equipment shall be acquired for each of the clinical laboratories located at the VISN facilities listed. The government reserves the right to add additional VISN 1 sites.
- 2.1.3. The Contractor is required to provide a continuously stocked inventory of reagents, standards, controls, supplies, disposables, and any other materials required to properly perform tests on the equipment such that equipment operations are not interrupted. These items shall be of the highest quality, sensitivity, specificity and tested to assure precision and accuracy.
 - 2.1.3.1. Expiration date must be clearly marked on reagent, standards, and control containers.
 - 2.1.3.2. Reagents and supplies are FOB destination with 2-day shipping upon order. No additional shipping may be charged.
 - 2.1.3.3. Any delays in shipping must be communicated to the ordering sites point of contact (POC) and the Network Consolidated Laboratory (NCL) group. All backorders of reagents and consumables must be communicated to all participating sites POCs as well as the NCL group as soon as it is known there will be a backorder of inventory. The vendor will work closely with the NCL group to monitor and adjust inventory levels across the VISN to ensure there is no break in testing.
 - 2.1.3.4. Changes in methodology/technology shall be at the expense of the Contractor. Any change in methodology, reagent formulation, assay parameters, etc must be communicated to the NCL group and VISN 1 site POCs as soon as possible, and no less than 60 days prior to requirement of the change.
 - 2.1.3.5. Product Alerts, Product Notifications, Technical Advisories, Recalls, Software Updates or any other important communications must be provided to both the NCL group and the VISN 1 POCs at each site.
 - 2.1.3.6. NCL and VISN 1 POCs are provided in section 3 of this document.
- 2.1.4. Special handling for emergency orders of supplies:
 - 2.1.4.1. In the event that the supplies are found to be defective and unsuitable for use with the Contractor's equipment, or the Contractor has failed to comply with the requirements for routine supply delivery, the Contractor is required to deliver the supplies within 24 hours of receipt of a verbal order for emergency delivery. If either circumstance has occurred, the Contractor shall deliver to the Government site in the most expeditious manner possible without additional cost to the Government, the necessary consumables in sufficient quantity as required to allow operation of the Contractor's equipment for one week (under normal Government test load volume). If additional requests for emergency supply delivery are required by the Government, they shall be honored by the Contractor until the arrival at the laboratory of the regularly scheduled standing order/routine supplies delivery.
 - 2.1.4.2. In the event that the government requires a rush delivery due to inventory levels unrelated to contractor performance, the government shall cover reasonable expedited shipping charges

2.2. DEFINITIONS:

2.2.1. **Cost per Test (CPT)**- *as defined in the Federal Supply Schedule FSC Group 66, Part III, Cost-Per-Test Clinical Laboratory Analyzers* – Contractors are required to provide a price for each test that can be performed on its equipment. The per test price shall include costs covering (1) 5 year equipment use; (2) all reagents, standards, quality controls, supplies, consumable/disposable items, parts, accessories and any other item required for the proper operation of the Contractor's equipment and necessary for the generation and reporting of a test result; (3) all necessary maintenance to keep the equipment in good operating condition (This element includes both preventive maintenance and emergency repairs); and (4) training for Government personnel. Contractors are required to provide delivery, installation and removal of equipment at no additional charge.

2.2.2. **Business Associate Agreement (BAA)**- A business associate is an entity, including an individual, company, or organization that, on behalf of VHA, performs or assists in the performance of functions or activities involving the use or disclosure of PHI, or that provides certain services involving the disclosure of protected health information (PHI). VHA is a covered entity under the HIPAA Privacy Rule (Privacy Rule). HIPAA regulations require VHA to execute HIPAA-compliant BAAs with certain entities that receives, uses, or discloses VHA PHI in order to perform some activity for VHA. These BAAs obligate VHA business associates to provide the same protections and safeguards to PHI that is required of VHA under the Privacy Rule.

2.2.3. **Contractor Middleware Management System** - For the purposes of this solicitation, this is a separate component or module that electronically connects the testing instrumentation to manage data, results, and workflow of 2 or more pieces of instrumentation. (Not to be confused with middleware for interfacing equipment with the hospital/laboratory information system.)

2.2.4. **Throughput** – The speed that the equipment processes and/or operates reported in units per hour.

2.3. TEST MENU:

Item #	Description
245115	Tube Pza Medium 25 Pak MGIT 960
245122	Tube Bactec MGIT 7MI
245123	Kit Bactec MGIT 960 Sire
245124	Kit Bactec MGIT 960 Supplement 100 Test
245128	Kit Drug Pza MGIT
445871	Kit Calibrator MGIT 960 51 Pk

2.4. GENERAL REQUIREMENTS:

2.4.1. Operational and Technical Features:

- 2.4.1.1. A single analyzer system capable of both primary isolation and susceptibility testing for *Mycobacterium tuberculosis*
- 2.4.1.2. On-board incubation with no need to transfer tubes once the system has been loaded
- 2.4.1.3. Automatic susceptibility or resistance interpretation
- 2.4.1.4. Continuous monitoring for positives with both a visual and audible notification
- 2.4.1.5. Nonradiometric
- 2.4.1.6. Thruput of 8000 specimens per year
- 2.4.1.7. Automated quality control that provides numerical growth units as well as a positive or negative result
- 2.4.2. **Testing Instrumentation:** The testing instrumentation must be approved by the Food and Drug Administration (FDA) for all tests in the required test menu at the time of proposal
- 2.4.3. **Hardware Features:**
 - 2.4.3.1. All monitors/screens will clearly display information in all light conditions.
 - 2.4.3.2. A printer(s) that has the capability of printing a patient report with patient demographic information that includes minimally the patient's name and accession or unique identifier number (UID). If printer(s) will not be provided the instruments must have the capability of attaching a local printer and a list of compatible printers will be provided.
 - 2.4.3.3. An uninterruptible power supply (UPS) with line conditioner for each instrument provided. (This includes UPS units for sites with automation lines, specimen management systems, data management systems, refrigerated storage, etc.) Each UPS must provide electrical power for a minimum of 15 minutes after electrical power fails and the system must allow for an automatic controlled shutdown to prevent damage to the instrument and data records
 - 2.4.3.4. The vendor will include up to two instrument moves over the full period of performance, including option periods per instrument, due to laboratory renovation, repair, etc.
- 2.4.4. **Method Performance/Validation Requirements:**
 - 2.4.4.1. The Contractor shall assist each site in the performance of all comparison and validation studies to include any materials and reagents needed for such correlation at no cost to the Government. The Contractor shall perform all statistical analysis, as applicable, and report data in an organized, clearly comprehensible format. This process shall be consistent with current CLSI Standards and related documents, College of American Pathologists (CAP)/ The Joint Commision (TJC) standards, VA guidelines, and Federal Regulations.
- 2.4.5. **Reports:** The Contractor shall provide to the Contracting Officer and other individuals (designated post-award) a copy of a quarterly report of sales, by ordering facility, within 30 calendar days after the close of each quarter's business. Reports are to reflect, at a minimum, total net sales amounts before discount, and discount amounts by ordering facility as well as the raw data used to develop these reports. There will be no additional charges for any reports required as part of the BPA. These reports will be in an Excel spreadsheet; multiple tabs may be used, to include a VISN summary tab.

2.4.6. Support Features:

- 2.4.6.1. **Commercial marketing.** The equipment models being offered shall be in current production as of the date this offer is submitted. For purposes of this solicitation, “current production” shall mean that the clinical laboratory analyzer model is being offered as new equipment. Discontinued models that are only being made available as remanufactured equipment are not acceptable.
- 2.4.6.2. **Start-Up Reagents.** The Contractor shall provide all reagents, calibrators, controls, consumable/disposable items, parts, accessories and any other item included on the list of supplies required to establish instruments for operation for performance of acceptance testing. This applies to all equipment as well as additional or replacement equipment placed under the terms and conditions of this BPA. The Contractor shall perform/assist, to the satisfaction of the Government, all validation studies including: precision, method comparison with current analyzer, accuracy (recovery), linearity (reportable range), calibration verification, verification of reference interval, and determination of sensitivity and specificity at no cost to the Government. The Contractor shall perform all of the statistical analysis as stated in the Method Performance/Validation section above and provide a hard-copy of data in an organized, clearly comprehensible format.
- 2.4.6.3. **Training.** The Contractor shall include an instrument training program that is coordinated with and timely to the equipment installation, sufficient to the size and scope of the facility’s services. This shall include training on the operation of the system, data manipulation, basic and advanced trouble shooting and repair. Thereafter, the Contractor shall provide training for minimally one operator per facility per year at the discretion of the Government for each model of instrumentation placed. Utilization of the training slots shall be mutually agreed upon between the VA and the Contractor. A training program that involves off-site travel shall include the cost of airfare, room and board for each participant.
- 2.4.6.4. **Equipment Preventative Maintenance/Repair Service.** The Contractor shall be able to provide emergency equipment repair and preventative maintenance on all instrumentation, and any incremental support/ancillary equipment, e.g. printers, etc. offered according to the following terms:
- 2.4.6.4.1. Preventative maintenance will be performed as frequently as published in manufacturer’s operator’s manual and within 2 weeks of the scheduled due date. Maintenance will be coordinated and performed at a mutually acceptable time with the laboratory supervisor and clinically engineering staff.
- 2.4.6.4.2. Daily, weekly, and monthly maintenance will be performed by the end users. All other scheduled maintenance (i.e. quarterly, tri-annually, annually) will be performed by the vendor.

2.4.6.4.3. A technical assistance center shall be available by telephone 24 hours per day, 7 days per week, 365 days a year, with a maximum call back response time of 30 minutes.

1.1.1.1.1. Equipment repair service shall be provided at a mutually acceptable time coordinated with the laboratory staff. Certain circumstances may dictate the need for repair service to be conducted outside routine business hours. All such arrangements shall be coordinated between the Contractor and VA laboratory personnel.

1.1.1.1.2. Equipment repair response time shall be no more than 48 hours.

1.1.1.1.3. Equipment service hours are Monday-Friday 8am-5pm unless otherwise specified. Vendor must clearly state the service option included in this offer. Including which hours and days are covered. Any times or days not covered by this offer must stated (i.e. weekends, holidays (Federal or other, including company holidays), off hours, etc). If multiple service package options are available, the vendor will provide these options at solicitation with pricing for each. Each VISN 1 site included in this solicitation will choose the service option that best suits the need of that site.

2.4.6.4.4. Service and repair calls starting within the service hours will not incur additional charges if the service technician has not completed repair and stays past the service hours.

2.4.6.4.5. A malfunction incident report shall be furnished to the Laboratory upon completion of each repair call within 5 days. The report shall include, as a minimum, the following:

2.4.6.4.5.1. date and time notified

2.4.6.4.5.2. date and time of arrival

2.4.6.4.5.3. serial number, type, and model number of equipment

2.4.6.4.5.4. description of the issue and resolution

2.4.6.4.5.5. time spent for repair, and

2.4.6.4.5.6. proof of repair that includes documentation of a sample run of quality control verifying acceptable performance.

2.4.6.4.6. Each notification for an emergency repair service call shall be treated as a separate and new service call.

2.4.6.5. **Upgrades** - The Contractor shall provide upgrades to both the equipment hardware and software in order to maintain the integrity of the system and the state-of-the-art technology, at no additional charge to the Government. These upgrades will include any current/future VA mandated hardware or software requirements. These shall be provided as they become commercially available and at the same time as they are being provided to commercial customers. This requirement only applies to “system upgrades” that enhance the model of equipment being offered, i.e., new version of software, correction of hardware defect, upgrade offered to commercial customers at no additional charge, upgrade to replace model of equipment no longer Contractor supported, etc. This does not refer to replacing the original

piece of equipment provided under the BPA; however, it does refer to significant changes in the hardware operational capability.

2.4.6.6. **Ancillary support equipment** - The Contractor shall provide, install and maintain through the life of the BPA, as indicated, any and all ancillary support equipment to fully operate each analyzer independently as defined in these specifications, e.g. computers, keyboard, mouse, printers and universal interface equipment, table/cabinetry to support/house the analyzer (if necessary) etc. When multiple analyzers are included in the offer, each must have its own ancillary support equipment. In addition, the Contractor shall include all ancillary components that are customarily sold or provided with the model of equipment proposed, e.g., starter kits, tables/stands, etc.

2.4.6.7. Interface Requirements-

2.4.6.7.1. The Contractor shall provide any and all necessary software support for ensuring that successful interfacing has been established. Specific requirements for the communication of the data streams will be unique to the instrument system involved and dictated by the manufacturer itself. Information necessary to make the determination for type and amount of interfacing equipment is supplied in Attachment A.

2.4.6.7.2. If a site already has a universal interface system, the Contractor is responsible for any additional hardware and everything leading up to the connection to the software system, including any incremental fee required to add additional equipment (e.g. licenses, ports/cards, cables, software, etc.) to the universal interfacing system.

2.4.6.7.3. If there are any software upgrades in the instrument during its life, the Contractor is responsible for seeing that the interface can accommodate any changes in the data stream going to the VA computerized hospital information system.

2.4.6.7.4. The Specimen Management system must be computer interface compatible with the current VA laboratory information system and existing universal interface. The fully operational interface (both hardware and software) shall be immediately available for implementation to the VA computerized hospital information system.

2.4.6.8. **Commercial offerings** - The Contractor shall provide any additional support material that is routinely provided to equivalent commercial customers and assists in regulatory compliance, e.g. Computer disc containing their procedure manual in CLSI format or an on-line procedure manual in the instrument software.

2.4.6.9. **Characterization of waste** – The Contractor shall provide documentation that it has characterized the hazardous nature of all wastes produced by all equipment, devices, reagents, and discharges in accordance with the requirements of the Code of Federal Regulations Title 40 “Protection of the Environment” Part 261 et seq. and applicable state and local requirements. Documentation shall include a description of the characteristics of the hazardous waste produced as a byproduct of the instrument operations, Safety Data Sheets

(SDS) meeting the requirements of the Occupational Safety and Health Administration (OSHA) and Environmental Protection Agency (EPA), the analytical process used to determine the hazardous nature and characteristics of the waste, and the analytical test results. Testing of hazardous waste is to be done in accordance with testing protocol specified for each individual waste as described in the Code of Federal Regulations Title 40 to make a determination if the waste is a hazardous waste or otherwise regulated.

2.4.6.9.1. The determination and description shall address the following:

2.4.6.9.1.1. Waste toxicity (Reference 40 CFR §261.11 and 40 CFR §261.24)

2.4.6.9.1.2. Waste ignitability (Reference 40 CFR §261.21)

2.4.6.9.1.3. Waste corrosivity (Reference 40 CFR §261.22)

2.4.6.9.1.4. Waste reactivity (Reference 40 CFR §261.23)

2.4.6.9.1.5. Hazardous waste from non-specific sources (F-listed) (Reference 40 CFR §261.31)

2.4.6.9.1.6. Discarded commercial products (acutely toxic or P-listed and toxic or U-listed) (Reference 40 CFR §261.33)

2.4.6.9.1.7. Solid Waste (Reference 40 CFR §261.2)

2.4.6.9.1.8. Exclusions (Reference 40 CFR §261.4)

2.4.6.9.2. The contractor will provide written instructions and training material to ensure VHA laboratory staff are trained as needed to properly operate devices with special emphasis to managing and disposing of hazardous waste in accordance with EPA and state requirements. Additionally, the training provided by the contractor must fulfill Resource Conservation and Recovery Act (RCRA) requirements for training as applicable to devices.

2.4.6.9.3. Contractor shall provide a description of all wastes the process or equipment may discharge so that the facility can determine whether the discharge meets Local Publicly Owned Treatment Works (POTW), State and Federal discharge requirements. At a minimum the characteristics of ignitability, corrosivity, reactivity and toxicity as defined in 40 CFR §261 must be determined and documented. Any mercury containing reagents must be identified in any concentrations. All test results shall be provided. All listed chemicals (F, U, K and P) found in 40 CFR §261 shall be provided in product information and their concentrations documented. For those materials with a positive hazardous waste determination, a mechanism for the laboratory to meet local discharge requirements (i.e., mercury, thimerosal, and formaldehyde) must be developed and SDS sheets must be provided in advance for review. At a minimum, documentation shall include, but not be limited to the concentration/measures of the elements and parameters listed below and must be included with vendor response: Total -Barium, Cadmium,

Chromium, Copper, Cyanide, Lead, Mercury, Nickel, Silver, Zinc, Arsenic, Selenium, Tin, pH , Flash point (to higher than 200°F), BOD; biochemical oxygen demand

2.4.6.9.4. The documentation the contractor provides will be used to work with the VAMC and the public and/or private organization (e.g., POTW) to determine whether or not the waste from each device can legally be disposed of via the sewage system.

2.4.6.10. **Implementation/transition timeframe** - The implementation of the services/requirements described in this solicitation shall be completed no later than 120 days after the award of the BPA. This timeline is based on a reasonable attempt of the Contractor to complete all of the necessary implementation requirements within the stated timeframe. Contractor shall not be penalized for implementation timelines that extend beyond the 120-day timeframe if the extension is through no fault of the Contractor and is a result of delays due to the Government.

2.4.6.10.1. Upon award of a BPA, the transition period for the awarded BPA to have all equipment and peripherals installed and operational shall be from date of award through 120 days. During this same period all initial training of VA personnel in the operation and maintenance of said award shall also be completed.

2.4.7. Standard and Quality of Performance:

2.4.7.1. This paragraph establishes a standard of quality performance that shall be met before any equipment listed on the delivery order [or BPA] is accepted by the Government. This also includes replacement, substitute instruments and instruments that are added or field modified after a system has demonstrated successful performance. The acceptance period shall begin on the installation date. It shall end when the equipment has met the standard of performance for a period of 30 consecutive calendar days by operating in conformance with the Contractor's technical specification or as quoted in any proposal at an effectiveness level of 90% or more.

2.4.7.2. In the event that equipment does not meet the standard of performance during the initial 30 consecutive calendar days, the standard of performance tests shall continue on a day-by-day basis until the standard of performance is met for a total of 30 consecutive days.

2.4.7.3. If the equipment fails to meet the standard of performance after 90 calendar days from the installation date, the user may, at his/her option, request a replacement or terminate the order in accordance with the provisions of FAR 52.212-4 entitled "Termination for cause." (The Contractor shall receive revenue for tests reported during the 90-day acceptance period.)

2.4.7.4. Operational use time for performance testing for a system is defined as the accumulated time during which the machine is in actual use. System failure downtime is that period of time when any machine in the system is inoperable due to equipment failure. Downtime for each incident shall start from the time the Government makes a bona fide attempt to contact the

Contractor's designated representative at the prearranged contact point until the system or machine(s) is returned to the Government in proper operating condition.

2.4.7.5. During the performance period for a system, a minimum of 100 hours of operational use time with productive or simulated work shall be required as a basis for computation of the effectiveness level. However, in computing the effectiveness level, the actual number of operational use hours shall be used when in excess of the minimum of 100 hours.

2.4.7.6. The Government will maintain daily records to satisfy the requirements of the Standard and Quality of Performance section and shall notify the Contractor in writing of the date of the first day of the successful period of operation. Operations use time and downtime shall be measured in hours and whole minutes.

2.4.7.7. During the term of the BPA, should the repair record of any individual piece of laboratory equipment reflect a downtime of 10% or greater of the normal working days in one calendar month, a determination shall be made by the COR and/or contracting officer to replace the malfunctioning equipment with new equipment. The responsibility for maintaining the equipment furnished in good condition in accordance with manufacturer's instructions, shall be solely that of the Contractor. Each instrument provided by the Contractor shall maintain an uptime of 90% in each month of the term of the agreement for equipment. The same terms and conditions apply to ancillary/support equipment provided under this BPA, i.e., water system UPS, etc.

2.4.8. Security Requirements:

2.4.8.1. The Contractor shall follow all Government rules and regulations regarding information security to prevent disclosure of sensitive information to unauthorized individuals or organizations, and shall adhere to all VA Privacy & Security, the Privacy Act and HIPAA requirements when obtaining and reviewing information.

2.4.9. Government's Responsibility:

2.4.9.1. The user will perform routine maintenance and cleaning as required in the manufacturer's operation and maintenance instructions. The user shall maintain appropriate records to satisfy the requirements of this paragraph.

2.4.10. Ownership of Equipment:

2.4.10.1. Title to the equipment shall remain with the Contractor. All accessories (unused consumables, etc.) furnished by the Contractor shall accompany the equipment when returned to the Contractor. The Contractor, upon expiration of order(s), at termination and/or replacement of equipment, shall remove the equipment. The Contractor shall disconnect the analyzer (gas, water, air, etc.) and shall be responsible for all packing and shipping required to remove the analyzer.

2.4.10.2. The Contractor will identify if removable media is required to perform their duties. The Clinical Engineering Department will ensure the removable media is scanned with anti-virus software running current virus definitions prior to connection to any medical device/system. Any Contractor with patient sensitive information that is imported into the removable media

device for any reason must purge all patient sensitive information prior to departure from the facility.

- 2.4.10.3. Prior to termination or completion of this BPA, Contractor/subcontractor must not destroy information received from VA, or gathered/created by the Contractor in the course of performing this BPA without prior written approval by the VA. Any data destruction done on behalf of VA by a Contractor/subcontractor must be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, Records and Information Management and its Handbook 6300.1 Records Management Procedures, applicable VA Records Control Schedules, and VA Handbook 6500.6, Electronic Media Sanitization. Self-certification by the Contractor that the data destruction requirements above have been met must be sent to the VA Contracting Officer within 30 days of termination or completion of the BPA.
- 2.4.10.4. All electronic storage media used on non-VA leased or non-VA owned IT equipment that is used to store, process, or access VA information must be handled in adherence with VA Handbook 6500.6, Electronic Media Sanitization upon: (i) completion or termination of the BPA or (ii) disposal or return of the IT equipment by the Contractor/subcontractor or any person acting on behalf of the Contractor/subcontractor, whichever is earlier. Media (hard drives, optical disks, CDs, back-up tapes, etc.) used by the Contractors/subcontractors that contain VA information must be retained by the VA for sanitization or destruction or the Contractor/subcontractor must self-certify that the media has been disposed of per 6500.6 requirements. This must be completed within 30 days of termination or completion of the BPA or disposal or return of the IT equipment, whichever is earlier.
- 2.4.10.5. Bio-Medical devices and other equipment or systems containing media (hard drives, optical disks, etc.) with VA sensitive information must not be returned to the Contractor at the end of lease, for trade-in, or other purposes. The options are:
 - 2.4.10.5.1. Contractor must accept the system without the drive; or
 - 2.4.10.5.2. VA's initial medical device procurement includes a spare drive which must be installed in place of the original drive at time of turn-in; or
 - 2.4.10.5.3. VA must reimburse the company for media at a reasonable open market replacement cost at time of purchase.
- 2.4.10.6. Due to the highly specialized and sometimes proprietary hardware and software associated with medical equipment/systems, if it is not possible for the VA to retain the hard drive, then;
- 2.4.10.7. The equipment Contractor must have an existing BAA if the device being traded in has protected health information stored on it and hard drive(s) from the system are being returned physically intact; and
- 2.4.10.8. Any fixed hard drive on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient

data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the purchase order or BPA.

- 2.4.10.9. A statement needs to be signed by the Director (System Owner) that states that the drive could not be removed and that the controls above are in place and completed. The Information Security Officer (ISO) needs to maintain the documentation.

3. Contacts

3.1. NCL Group

NCL Group	VISN1LabNCL@va.gov
Wendy Strollo	203-841-5591
Jacqueline LaCroix	203-980-6063
Holly Charpentier	802-296-1349
Jacqueline Hite	203-601-0563
Jean McElreavy	603-203-1872

3.2. VISN 1 POCs

FACILITY NAME	DELIVERY LOCATION	HOURS OF OPERATION	POINT OF CONTACT	TEL #
VA, BHS, West Roxbury	1400 VFW Parkway, West Roxbury, MA 02132	24X7	Arthur.Mcgee@va.gov	857-203-5993
VA BHS, Jamaica Plain	150 South Huntington Ave, Boston, MA 02130	M-F 7am- 6pm	Joseph.Manzone@va.gov	857-364-5092
VA BHS, Brockton	940 Belmont Street, Brockton, MA 02301	M-F 7am- 8pm	Diane.Robert@va.gov	774-826-2294
VA Bedford	200 Springs Road, Bedford, MA 01730	M-F 7am - 6pm	Rita.Rocha@va.gov	781-687-3814
VA Connecticut, West Haven	950 Campbell Ave, West Haven, CT 06516	24X7	Kerrie.Larisa@va.gov	203-932-5711 ext.2969
VA Connecticut, Newington	555 Willard Ave, Newington, CT 06111	M-F 7am - 6pm	Maria.Scarfone@va.gov	860-666-6951 ext.6480
VA Maine, Togus	1 VA Center, Augusta, ME 04330	24X7	Lori.Browne@va.gov	207-623-8411 ext. 5600
VA Manchester	718 Smyth Road, Manchester, NH 03104	M-F 7am- 11pm	Monica.Zukovic@va.gov	603-624-4366 ext. 6638
VA CWM, Leeds	421 North Main Street, Leeds, MA 01060	M-F 6am- 8pm	Lisa.Decoteau@va.gov	413-584-4040 ext. 2382

VA CWM, Worcester	605 Lincoln Street, Worcester, MA 01605	M-F 8am - 4:30pm	Lisa.Decoteau@va.gov	413-584-4040 ext. 2382
VA White River Junction	215 North Main Street, White River Junction, VT 05009	24X7	Robert.Smith@va.gov	802-295-9363 ext. 5500
VA Providence	830 Chalkstone Avenue, Providence, RI 02908	24X7	Gina.Hawthorne@va.gov	401-273-7100 ext. 13143

Privacy Language for Statement of Work (SOW)

Contractor policies and procedures shall comply with all VA Privacy & Security, the Privacy Act and Health Insurance Portability and Accountability Act (HIPAA).

Records Management Language for Statement of Work (SOW):

The following standard items relate to records generated in executing the contract and should be included in a typical procurement contract:

1. Citations to pertinent laws, codes and regulations such as 44 U.S.C chapters 21, 29, 31 and 33; Freedom of Information Act (5 U.S.C. 552); Privacy Act (5 U.S.C. 552a); 36 CFR Part 1222 and Part 1228.
2. Contractor shall treat all deliverables under the contract as the property of the U.S. Government for which the Government Agency shall have unlimited rights to use, dispose of, or disclose such data contained therein as it determines to be in the public interest.
3. Contractor shall not create or maintain any records that are not specifically tied to or authorized by the contract using Government IT equipment and/or Government records.
4. Contractor shall not retain, use, sell, or disseminate copies of any deliverable that contains information covered by the Privacy Act of 1974 or that which is generally protected by the Freedom of Information Act.
5. Contractor shall not create or maintain any records containing any Government Agency records that are not specifically tied to or authorized by the contract.
6. The Government Agency owns the rights to all data/records produced as part of this contract.
7. The Government Agency owns the rights to all electronic information (electronic data, electronic information systems, electronic databases, etc.) and all supporting documentation created as part of this contract. Contractor must deliver sufficient technical documentation with all data deliverables to permit the agency to use the data.
8. Contractor agrees to comply with Federal and Agency records management policies, including those policies associated with the safeguarding of records covered by the Privacy Act of 1974. These policies include the preservation of all records created or received regardless of format [paper, electronic, etc.] or mode of transmission [e-mail, fax, etc.] or state of completion [draft, final, etc.].
9. No disposition of documents will be allowed without the prior written consent of the Contracting Officer. The Agency and its contractors are responsible for preventing the alienation or unauthorized destruction of records, including all forms of mutilation. Willful and unlawful destruction, damage or alienation of Federal records is subject to the fines and penalties imposed by 18 U.S.C. 2701. Records may not be removed from the legal

custody of the Agency or destroyed without regard to the provisions of the agency records schedules.

10. Contractor is required to obtain the Contracting Officer's approval prior to engaging in any contractual relationship (sub-contractor) in support of this contract requiring the disclosure of information, documentary material and/or records generated under, or relating to, this contract. The Contractor (and any sub-contractor) is required to abide by Government and Agency guidance for protecting sensitive and proprietary information.

VA INFORMATION AND INFORMATION SYSTEM SECURITY/PRIVACY LANGUAGE FOR INCLUSION INTO CONTRACTS, AS APPROPRIATE

1. GENERAL

Contractors, contractor personnel, subcontractors, and subcontractor personnel shall be subject to the same Federal laws, regulations, standards, and VA Directives and Handbooks as VA and VA personnel regarding information and information system security.

2. ACCESS TO VA INFORMATION AND VA INFORMATION SYSTEMS

a. A contractor/subcontractor shall request logical (technical) or physical access to VA information and VA information systems for their employees, subcontractors, and affiliates only to the extent necessary to perform the services specified in the contract, agreement, or task order.

b. All contractors, subcontractors, and third-party servicers and associates working with VA information are subject to the same investigative requirements as those of VA appointees or employees who have access to the same types of information. The level and process of background security investigations for contractors must be in accordance with VA Directive and Handbook 0710, *Personnel Suitability and Security Program*. The Office for Operations, Security, and Preparedness is responsible for these policies and procedures.

c. Contract personnel who require access to national security programs must have a valid security clearance. National Industrial Security Program (NISP) was established by Executive Order 12829 to ensure that cleared U.S. defense industry contract personnel safeguard the classified information in their possession while performing work on contracts, programs, bids, or research and development efforts. The Department of Veterans Affairs does not have a Memorandum of Agreement with Defense Security Service (DSS). Verification of a Security Clearance must be processed through the Special Security Officer located in the Planning and National Security Service within the Office of Operations, Security, and Preparedness.

d. Custom software development and outsourced operations must be located in the U.S. to the maximum extent practical. If such services are proposed to be performed abroad and are not disallowed by other VA policy or mandates, the contractor/subcontractor must state where all non-U.S. services are provided and detail a security plan, deemed to be acceptable by VA, specifically to address mitigation of the resulting problems of communication, control, data protection, and so forth. Location within the U.S. may be an evaluation factor.

e. The contractor or subcontractor must notify the Contracting Officer immediately when an employee working on a VA system or with access to VA information is reassigned or leaves the contractor or subcontractor's employ. The Contracting Officer must also be notified immediately by the contractor or subcontractor prior to an unfriendly termination.

3. VA INFORMATION CUSTODIAL LANGUAGE

a. Information made available to the contractor or subcontractor by VA for the performance or administration of this contract or information developed by the contractor/subcontractor in performance or

administration of the contract shall be used only for those purposes and shall not be used in any other way without the prior written agreement of the VA. This clause expressly limits the contractor/subcontractor's rights to use data as described in Rights in Data - General, FAR 52.227-14(d) (1).

b. VA information should not be co-mingled, if possible, with any other data on the contractors/subcontractor's information systems or media storage systems in order to ensure VA requirements related to data protection and media sanitization can be met. If co-mingling must be allowed to meet the requirements of the business need, the contractor must ensure that VA's information is returned to the VA or destroyed in accordance with VA's sanitization requirements. VA reserves the right to conduct on site inspections of contractor and subcontractor IT resources to ensure data security controls, separation of data and job duties, and destruction/media sanitization procedures are in compliance with VA directive requirements.

c. Prior to termination or completion of this contract, contractor/subcontractor must not destroy information received from VA, or gathered/created by the contractor in the course of performing this contract without prior written approval by the VA. Any data destruction done on behalf of VA by a contractor/subcontractor must be done in accordance with National Archives and Records Administration (NARA) requirements as outlined in VA Directive 6300, *Records and Information Management* and its Handbook 6300.1 *Records Management Procedures*, applicable VA Records Control Schedules, and VA Handbook 6500.1, *Electronic Media Sanitization*. Self-certification by the contractor that the data destruction requirements above have been met must be sent to the VA Contracting Officer within 30 days of termination of the contract.

d. The contractor/subcontractor must receive, gather, store, back up, maintain, use, disclose and dispose of VA information only in compliance with the terms of the contract and applicable Federal and VA information confidentiality and security laws, regulations and policies. If Federal or VA information confidentiality and security laws, regulations and policies become applicable to the VA information or information systems after execution of the contract, or if NIST issues or updates applicable FIPS or Special Publications (SP) after execution of this contract, the parties agree to negotiate in good faith to implement the information confidentiality and security laws, regulations and policies in this contract.

e. The contractor/subcontractor shall not make copies of VA information except as authorized and necessary to perform the terms of the agreement or to preserve electronic information stored on contractor/subcontractor electronic storage media for restoration in case any electronic equipment or data used by the contractor/subcontractor needs to be restored to an operating state. If copies are made for restoration purposes, after the restoration is complete, the copies must be appropriately destroyed.

f. If VA determines that the contractor has violated any of the information confidentiality, privacy, and security provisions of the contract, it shall be sufficient grounds for VA to withhold payment to the contractor or third party or terminate the contract for default or terminate for cause under Federal Acquisition Regulation (FAR) part 12.

g. If a VHA contract is terminated for cause, the associated BAA must also be terminated and appropriate actions taken in accordance with VHA Handbook 1600.01, *Business Associate Agreements*. Absent an agreement to use or disclose protected health information, there is no business associate relationship.

h. The contractor/subcontractor must store, transport, or transmit VA sensitive information in an encrypted form, using VA-approved encryption tools that are, at a minimum, FIPS 140-2 validated.

i. The contractor/subcontractor's firewall and Web services security controls, if applicable, shall meet or exceed VA's minimum requirements. VA Configuration Guidelines are available upon request.

j. Except for uses and disclosures of VA information authorized by this contract for performance of the contract, the contractor/subcontractor may use and disclose VA information only in two other situations: (i) in response to a qualifying order of a court of competent jurisdiction, or (ii) with VA's prior written approval. The contractor/subcontractor must refer all requests for, demands for production of, or inquiries about, VA information and information systems to the VA contracting officer for response.

k. Notwithstanding the provision above, the contractor/subcontractor shall not release VA records protected by Title 38 U.S.C. 5705, confidentiality of medical quality assurance records and/or Title 38 U.S.C. 7332, confidentiality of certain health records pertaining to drug addiction, sickle cell anemia, alcoholism or alcohol abuse, or infection with human immunodeficiency virus. If the

contractor/subcontractor is in receipt of a court order or other requests for the above mentioned information, that contractor/subcontractor shall immediately refer such court orders or other requests to the VA contracting officer for response.

I. For service that involves the storage, generating, transmitting, or exchanging of VA sensitive information but does not require C&A or an MOU-ISA for system interconnection, the contractor/subcontractor must complete a Contractor Security Control Assessment (CSCA) on a yearly basis and provide it to the COTR.

4. INFORMATION SYSTEM DESIGN AND DEVELOPMENT

a. Information systems that are designed or developed for or on behalf of VA at non-VA facilities shall comply with all VA directives developed in accordance with FISMA, HIPAA, NIST, and related VA security and privacy control requirements for Federal information systems. This includes standards for the protection of electronic PHI, outlined in 45 C.F.R. Part 164, Subpart C, information and system security categorization level designations in accordance with FIPS 199 and FIPS 200 with implementation of all baseline security controls commensurate with the FIPS 199 system security categorization (reference Appendix D of VA Handbook 6500, *VA Information Security Program*). During the development cycle a Privacy Impact Assessment (PIA) must be completed, provided to the COTR, and approved by the VA Privacy Service in accordance with Directive 6507, *VA Privacy Impact Assessment*.

b. The contractor/subcontractor shall certify to the COTR that applications are fully functional and operate correctly as intended on systems using the VA Federal Desktop Core Configuration (FDCC), and the common security configuration guidelines provided by NIST or the VA. This includes Internet Explorer 7 configured to operate on Windows XP and Vista (in Protected Mode on Vista) and future versions, as required.

c. The standard installation, operation, maintenance, updating, and patching of software shall not alter the configuration settings from the VA approved and FDCC configuration. Information technology staff must also use the Windows Installer Service for installation to the default "program files" directory and silently install and uninstall.

d. Applications designed for normal end users shall run in the standard user context without elevated system administration privileges.

e. The security controls must be designed, developed, approved by VA, and implemented in accordance with the provisions of VA security system development life cycle as outlined in NIST Special Publication 800-37, *Guide for Applying the Risk Management Framework to Federal Information Systems*, VA Handbook 6500, *Information Security Program* and VA Handbook 6500.5, *Incorporating Security and Privacy in System Development Lifecycle*.

f. The contractor/subcontractor is required to design, develop, or operate a System of Records Notice (SOR) on individuals to accomplish an agency function subject to the Privacy Act of 1974, (as amended), Public Law 93-579, December 31, 1974 (5 U.S.C. 552a) and applicable agency regulations. Violation of the Privacy Act may involve the imposition of criminal and civil penalties.

g. The contractor/subcontractor agrees to:

(1) Comply with the Privacy Act of 1974 (the Act) and the agency rules and regulations issued under the Act in the design, development, or operation of any system of records on individuals to accomplish an agency function when the contract specifically identifies:

(a) The Systems of Records (SOR); and

(b) The design, development, or operation work that the contractor/subcontractor is to perform;

(1) Include the Privacy Act notification contained in this contract in every solicitation and resulting subcontract and in every subcontract awarded without a solicitation, when the work statement in the

proposed subcontract requires the redesign, development, or operation of a SOR on individuals that is subject to the Privacy Act; and

(2) Include this Privacy Act clause, including this subparagraph (3), in all subcontracts awarded under this contract which requires the design, development, or operation of such a SOR.

h. In the event of violations of the Act, a civil action may be brought against the agency involved when the violation concerns the design, development, or operation of a SOR on individuals to accomplish an agency function, and criminal penalties may be imposed upon the officers or employees of the agency when the violation concerns the operation of a SOR on individuals to accomplish an agency function. For purposes of the Act, when the contract is for the operation of a SOR on individuals to accomplish an agency function, the contractor/subcontractor is considered to be an employee of the agency.

(1) "Operation of a System of Records" means performance of any of the activities associated with maintaining the SOR, including the collection, use, maintenance, and dissemination of records.

(2) "Record" means any item, collection, or grouping of information about an individual that is maintained by an agency, including, but not limited to, education, financial transactions, medical history, and criminal or employment history and contains the person's name, or identifying number, symbol, or any other identifying particular assigned to the individual, such as a fingerprint or voiceprint, or a photograph.

(3) "System of Records" means a group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.

i. The vendor shall ensure the security of all procured or developed systems and technologies, including their subcomponents (hereinafter referred to as "Systems"), throughout the life of this contract and any extension, warranty, or maintenance periods. This includes, but is not limited to workarounds, patches, hotfixes, upgrades, and any physical components (hereafter referred to as Security Fixes) which may be necessary to fix all security vulnerabilities published or known to the vendor anywhere in the Systems, including Operating Systems and firmware. The vendor shall ensure that Security Fixes shall not negatively impact the Systems.

j. The vendor shall notify VA within 24 hours of the discovery or disclosure of successful exploits of the vulnerability which can compromise the security of the Systems (including the confidentiality or integrity of its data and operations, or the availability of the system). Such issues shall be remediated as quickly as is practical, but in no event longer than 15 days.

k. When the Security Fixes involve installing third party patches (such as Microsoft OS patches or Adobe Acrobat), the vendor will provide written notice to the VA that the patch has been validated as not affecting the Systems within 10 working days. When the vendor is responsible for operations or maintenance of the Systems, they shall apply the Security Fixes within 15 days.

l. All other vulnerabilities shall be remediated as specified in this paragraph in a timely manner based on risk, but within 60 days of discovery or disclosure. Exceptions to this paragraph (e.g. for the convenience of VA) shall only be granted with approval of the contracting officer and the VA Assistant Secretary for Office of Information and Technology.

5. INFORMATION SYSTEM HOSTING, OPERATION, MAINTENANCE, OR USE

a. For information systems that are hosted, operated, maintained, or used on behalf of VA at non-VA facilities, contractors/subcontractors are fully responsible and accountable for ensuring compliance with all HIPAA, Privacy Act, FISMA, NIST, FIPS, and VA security and privacy directives and handbooks. This includes conducting compliant risk assessments, routine vulnerability scanning, system patching and change management procedures, and the completion of an acceptable contingency plan for each system. The contractor's security control procedures must be equivalent, to those procedures used to secure VA systems. A Privacy Impact Assessment (PIA) must also be provided to the COTR and approved by VA

Privacy Service prior to operational approval. All external Internet connections to VA's network involving VA information must be reviewed and approved by VA prior to implementation.

b. Adequate security controls for collecting, processing, transmitting, and storing of Personally Identifiable Information (PII), as determined by the VA Privacy Service, must be in place, tested, and approved by VA prior to hosting, operation, maintenance, or use of the information system, or systems by or on behalf of VA. These security controls are to be assessed and stated within the PIA and if these controls are determined not to be in place, or inadequate, a Plan of Action and Milestones (POA&M) must be submitted and approved prior to the collection of PII.

c. Outsourcing (contractor facility, contractor equipment or contractor staff) of systems or network operations, telecommunications services, or other managed services requires certification and accreditation (authorization) (C&A) of the contractor's systems in accordance with VA Handbook 6500.3, *Certification and Accreditation* and/or the VA OCS Certification Program Office. Government-owned (government facility or government equipment) contractor-operated systems, third party or business partner networks require memorandums of understanding and interconnection agreements (MOU-ISA) which detail what data types are shared, who has access, and the appropriate level of security controls for all systems connected to VA networks.

d. The contractor/subcontractor's system must adhere to all FISMA, FIPS, and NIST standards related to the annual FISMA security controls assessment and review and update the PIA. Any deficiencies noted during this assessment must be provided to the VA contracting officer and the ISO for entry into VA's POA&M management process. The contractor/subcontractor must use VA's POA&M process to document planned remedial actions to address any deficiencies in information security policies, procedures, and practices, and the completion of those activities. Security deficiencies must be corrected within the timeframes approved by the government. Contractor/subcontractor procedures are subject to periodic, unannounced assessments by VA officials, including the VA Office of Inspector General. The physical security aspects associated with contractor/subcontractor activities must also be subject to such assessments. If major changes to the system occur that may affect the privacy or security of the data or the system, the C&A of the system may need to be reviewed, retested and re-authorized per VA Handbook 6500.3. This may require reviewing and updating all of the documentation (PIA, System Security Plan, Contingency Plan). The Certification Program Office can provide guidance on whether a new C&A would be necessary.

e. The contractor/subcontractor must conduct an annual self assessment on all systems and outsourced services as required. Both hard copy and electronic copies of the assessment must be provided to the COTR. The government reserves the right to conduct such an assessment using government personnel or another contractor/subcontractor. The contractor/subcontractor must take appropriate and timely action (this can be specified in the contract) to correct or mitigate any weaknesses discovered during such testing, generally at no additional cost.

f. VA prohibits the installation and use of personally-owned or contractor/subcontractor-owned equipment or software on VA's network. If non-VA owned equipment must be used to fulfill the requirements of a contract, it must be stated in the service agreement, SOW or contract. All of the security controls required for government furnished equipment (GFE) must be utilized in approved other equipment (OE) and must be funded by the owner of the equipment. All remote systems must be equipped with, and use, a VA-approved antivirus (AV) software and a personal (host-based or enclave based) firewall that is configured with a VA-approved configuration. Software must be kept current, including all critical updates and patches. Owners of approved OE are responsible for providing and maintaining the anti-viral software and the firewall on the non-VA owned OE.

g. All electronic storage media used on non-VA leased or non-VA owned IT equipment that is used to store, process, or access VA information must be handled in adherence with VA Handbook 6500.1, *Electronic Media Sanitization* upon: (i) completion or termination of the contract or (ii) disposal or return of the IT equipment by the contractor/subcontractor or any person acting on behalf of the contractor/subcontractor, whichever is earlier. Media (hard drives, optical disks, CDs, back-up tapes, etc.) used by the contractors/subcontractors that contain VA information must be returned to the VA for

sanitization or destruction or the contractor/subcontractor must self-certify that the media has been disposed of per 6500.1 requirements. This must be completed within 30 days of termination of the contract.

h. Bio-Medical devices and other equipment or systems containing media (hard drives, optical disks, etc.) with VA sensitive information must not be returned to the vendor at the end of lease, for trade-in, or other purposes. The options are:

(1) Vendor must accept the system without the drive;

(2) VA's initial medical device purchase includes a spare drive which must be installed in place of the original drive at time of turn-in; or

(3) VA must reimburse the company for media at a reasonable open market replacement cost at time of purchase.

(4) Due to the highly specialized and sometimes proprietary hardware and software associated with medical equipment/systems, if it is not possible for the VA to retain the hard drive, then;

(a) The equipment vendor must have an existing BAA if the device being traded in has sensitive information stored on it and hard drive(s) from the system are being returned physically intact; and

(b) Any fixed hard drive on the device must be non-destructively sanitized to the greatest extent possible without negatively impacting system operation. Selective clearing down to patient data folder level is recommended using VA approved and validated overwriting technologies/methods/tools. Applicable media sanitization specifications need to be pre-approved and described in the purchase order or contract.

(c) A statement needs to be signed by the Director (System Owner) that states that the drive could not be removed and that (a) and (b) controls above are in place and completed. The ISO needs to maintain the documentation.

6. SECURITY INCIDENT INVESTIGATION

a. The term "security incident" means an event that has, or could have, resulted in unauthorized access to, loss or damage to VA assets, or sensitive information, or an action that breaches VA security procedures. The contractor/subcontractor shall immediately notify the COTR and simultaneously, the designated ISO and Privacy Officer for the contract of any known or suspected security/privacy incidents, or any unauthorized disclosure of sensitive information, including that contained in system(s) to which the contractor/subcontractor has access.

b. To the extent known by the contractor/subcontractor, the contractor/subcontractor's notice to VA shall identify the information involved, the circumstances surrounding the incident (including to whom, how, when, and where the VA information or assets were placed at risk or compromised), and any other information that the contractor/subcontractor considers relevant.

c. With respect to unsecured protected health information, the business associate is deemed to have discovered a data breach when the business associate knew or should have known of a breach of such information. Upon discovery, the business associate must notify the covered entity of the breach. Notifications need to be made in accordance with the executed business associate agreement.

d. In instances of theft or break-in or other criminal activity, the contractor/subcontractor must concurrently report the incident to the appropriate law enforcement entity (or entities) of jurisdiction, including the VA OIG and Security and Law Enforcement. The contractor, its employees, and its subcontractors and their employees shall cooperate with VA and any law enforcement authority responsible for the investigation and prosecution of any possible criminal law violation(s) associated with any incident. The

contractor/subcontractor shall cooperate with VA in any civil litigation to recover VA information, obtain monetary or other compensation from a third party for damages arising from any incident, or obtain injunctive relief against any third party arising from, or related to, the incident.

7. LIQUIDATED DAMAGES FOR DATA BREACH

a. Consistent with the requirements of 38 U.S.C. §5725, a contract may require access to sensitive personal information. If so, the contractor is liable to VA for liquidated damages in the event of a data breach or privacy incident involving any SPI the contractor/subcontractor processes or maintains under this contract.

b. The contractor/subcontractor shall provide notice to VA of a "security incident" as set forth in the Security Incident Investigation section above. Upon such notification, VA must secure from a non-Department entity or the VA Office of Inspector General an independent risk analysis of the data breach to determine the level of risk associated with the data breach for the potential misuse of any sensitive personal information involved in the data breach. The term 'data breach' means the loss, theft, or other unauthorized access, or any access other than that incidental to the scope of employment, to data containing sensitive personal information, in electronic or printed form, that results in the potential compromise of the confidentiality or integrity of the data. Contractor shall fully cooperate with the entity performing the risk analysis. Failure to cooperate may be deemed a material breach and grounds for contract termination.

c. Each risk analysis shall address all relevant information concerning the data breach, including the following:

(1) Nature of the event (loss, theft, unauthorized access);

(2) Description of the event, including:

(a) date of occurrence;

(b) data elements involved, including any PII, such as full name, social security number, date of birth, home address, account number, disability code; (3) Number of individuals affected or potentially affected;

(4) Names of individuals or groups affected or potentially affected;

(5) Ease of logical data access to the lost, stolen or improperly accessed data in light of the degree of protection for the data, e.g., unencrypted, plain text;

(6) Amount of time the data has been out of VA control;

(7) The likelihood that the sensitive personal information will or has been compromised (made accessible to and usable by unauthorized persons);

(8) Known misuses of data containing sensitive personal information, if any;

(9) Assessment of the potential harm to the affected individuals;

(10) Data breach analysis as outlined in 6500.2 Handbook, *Management of Security and Privacy Incidents*, as appropriate; and

(11) Whether credit protection services may assist record subjects in avoiding or mitigating the results of identity theft based on the sensitive personal information that may have been compromised.

d. Based on the determinations of the independent risk analysis, the contractor shall be responsible for paying to the VA liquidated damages in the amount of \$_100.00_ per affected individual to cover the cost of providing credit protection services to affected individuals consisting of the following:

(1) Notification;

(2) One year of credit monitoring services consisting of automatic daily monitoring of at least 3 relevant credit bureau reports;

(3) Data breach analysis;

(4) Fraud resolution services, including writing dispute letters, initiating fraud alerts and credit freezes, to assist affected individuals to bring matters to resolution;

- (5) One year of identity theft insurance with \$20,000.00 coverage at \$0 deductible; and
- (6) Necessary legal expenses the subjects may incur to repair falsified or damaged credit records, histories, or financial affairs.

8. SECURITY CONTROLS COMPLIANCE TESTING

On a periodic basis, VA, including the Office of Inspector General, reserves the right to evaluate any or all of the security controls and privacy practices implemented by the contractor under the clauses contained within the contract. With 10 working-day's notice, at the request of the government, the contractor must fully cooperate and assist in a government-sponsored security controls assessment at each location wherein VA information is processed or stored, or information systems are developed, operated, maintained, or used on behalf of VA, including those initiated by the Office of Inspector General. The government may conduct a security control assessment on shorter notice (to include unannounced assessments) as determined by VA in the event of a security incident or at any other time.

9. TRAINING

a. All contractor employees and subcontractor employees requiring access to VA information and VA information systems shall complete the following before being granted access to VA information and its systems:

(1) Sign and acknowledge (either manually or electronically) understanding of and responsibilities for compliance with the *Contractor Rules of Behavior*, Appendix E relating to access to VA information and information systems;

(2) Successfully complete the *VA Cyber Security Awareness and Rules of Behavior* training and annually complete required security training;

(3) Successfully complete the appropriate VA privacy training and annually complete required privacy training; and

(4) Successfully complete any additional cyber security or privacy training, as required for VA personnel with equivalent information system access *[to be defined by the VA program official and provided to the contracting officer for inclusion in the solicitation document – e.g., any role-based information security training required in accordance with NIST Special Publication 800-16, Information Technology Security Training Requirements.]*

b. The contractor shall provide to the contracting officer and/or the COTR a copy of the training certificates and certification of signing the Contractor Rules of Behavior for each applicable employee within 1 week of the initiation of the contract and annually thereafter, as required.

c. Failure to complete the mandatory annual training and sign the Rules of Behavior annually, within the timeframe required, is grounds for suspension or termination of all physical or electronic access privileges and removal from work on the contract until such time as the training and documents are complete.

VAAR (VA Acquisition Regulation) clause:

All contractors and subcontractors shall comply with conditions specified in VAAR 852.204-71(d); Contractor operations required to be in United States. All contractors and subcontractors working with VA information must be permanently located within a jurisdiction subject to the law of the United States or its Territories to the maximum extent feasible. If services are proposed to be performed abroad the contractor must state where all non-U.S. services are provided. The contractor shall deliver to VA a detailed plan specifically addressing communications, personnel control, data protection and potential legal issues. The plan shall be approved by the COR/CO in writing prior to access being granted. The A&A requirements do not apply, and a Security Accreditation Package is not required.